

Student Name: Ponsel Iliya

Course code: GRC104-P2—Practical Assessment (Hands-On Skills Test)

Registration No: 2025/GCR/12779

Exam Phase: Phase 1

Programme: GRC Engineering (CGRCE)

Batch: Batch B

SECTION A: Corporate Governance & National Data Breach Analysis

Question A1 — Root Cause Governance Analysis

The CAC breach is not just a technical story; it is fundamentally a governance story. When a national institution entrusted with millions of corporate and personal records falls victim to a threat actor like ByteToBreach, the technical vulnerabilities exposed are almost always the symptoms of deeper organizational and leadership failures that had been accumulating for years. Three critical Information Security Governance failures stand out.

1: Absence of a Functioning Risk Management Framework

The first and most foundational failure is the absence of a structured, continuously operating Information Security Risk Management framework. In a healthy governance environment, a body like the CAC would maintain a living risk register that regularly identifies, assesses, and treats threats to its information assets. Controls would be reviewed and tested, and findings would be escalated to senior leadership on a defined schedule.

The fact that a threat actor reportedly remained undetected within CAC's environment for an extended period tells us that no effective detection or monitoring mechanism was in place. This is characteristic of organizations where risk management exists only on paper policies are drafted to satisfy audit requirements but never operationalized into daily practice. Without continuous vulnerability scanning, privileged access reviews, and log monitoring, an attacker can move laterally through a network for months without triggering a single alert. In ISO 27001:2022 terms, this represents a direct failure against Annex A controls relating to Asset Management (A.5), Information Security Incident Management (A.5.24–A.5.28), and Monitoring, Analysis and Evaluation (Clause 9.1).

2: Inadequate Access Control and Identity Management

The second critical failure lies in poor identity and access management (IAM). National databases holding millions of sensitive corporate and personal records should operate on the principle of least privilege meaning every user, system, and service account is granted only the minimum access required to perform its function, and no more. Privileged accounts should be tightly controlled, time-bound, and continuously audited.

Extended dwell time by a threat actor almost always involves the abuse of valid credentials, either through credential theft, insider misuse, or the exploitation of over-privileged accounts that were never reviewed. When access reviews do not happen on a regular basis (ideally quarterly for privileged users), legacy accounts accumulate, service accounts carry unnecessarily broad permissions, and the blast radius of any single compromise becomes enormous. The CAC, as a government body, was also likely operating shared accounts across IT staff a practice that obliterates the audit trail and makes it nearly impossible to attribute malicious activity to a specific actor.

3: Lack of a Continuous Security Monitoring and Detection Capability

The third major governance failure is the complete absence of or total under-investment in a Security Operations capability. Whether that takes the form of a full Security Operations Centre (SOC) or a Managed Detection and Response (MDR) service, the point is that someone must be watching the network, interpreting log data, and correlating events in real time.

In most government institutions across Nigeria and indeed Africa, cybersecurity investment is treated as a capital expenditure to be justified once and then left to age. Firewalls are purchased, installed, and never updated. SIEM (Security Information and Event Management) tools are procured but misconfigured and then ignored because there is no dedicated team to review alerts. This creates what cybersecurity professionals call a detection blindspot, the organization is generating enormous volumes of security events, but nobody is interpreting them. A threat actor exploiting this environment can conduct reconnaissance, exfiltrate data, and cover their tracks over months without a single human reviewing the relevant log entries.

The Role of 'Tone at the Top' in Enabling These Failures

All three of the failures above have a common root: a leadership culture that has never made information security a strategic organizational priority. The concept of 'Tone at the Top' in governance refers to the attitude and behaviour that senior leadership Board members, Directors-General, Permanent Secretaries model and enforce regarding compliance, risk management, and ethical conduct.

When the tone at the top is weak on cybersecurity, the following chain of events becomes inevitable: Security teams are chronically understaffed and underfunded because leadership does not see the return on investment. Risk management frameworks exist as compliance theatre rather than operational tools. Technology refresh cycles are neglected, leaving critical systems

running on unpatched software for years. Security awareness training is sporadic or non-existent. Incident response plans are never tested, so when a crisis occurs, the organization is paralyzed.

In the CAC context, it is difficult to imagine that competent, empowered security personnel were raising concerns about unmonitored access, outdated systems, or the absence of breach detection and being heard. The more plausible picture is one where security was treated as an IT department issue rather than a Board-level business risk, where budget requests for security tooling were routinely deprioritized, and where the consequences of non-compliance were considered abstract rather than imminent. ISO 27001 Section 5 is explicit on this point: top management must demonstrate leadership and commitment to the ISMS, not merely delegate it downward.

Question A2 — Incident Notification & NDPC Compliance

The Nigeria Data Protection Act 2023 (NDPA) is the primary legal instrument governing the obligations of Data Controllers in Nigeria following a personal data breach. The CAC, in its capacity as a Data Controller managing corporate registration data and associated personal information of millions of Nigerians, is subject to the full weight of these obligations the moment it becomes aware or reasonably ought to become aware that a breach has occurred.

Notification to the Nigeria Data Protection Commission (NDPC)

Under Section 40(2) of the NDPA 2023, the CAC was legally obligated to notify the NDPC within 72 hours of becoming aware of the breach provided that the breach was of a nature likely to result in a risk to the rights and freedoms of the affected individuals. Given that millions of records were allegedly exposed, including sensitive personal and corporate data, this threshold was plainly met.

This 72-hour clock begins ticking from the moment of awareness, not from the moment the organization completes its internal investigation. Where it was not possible to provide all required information to the NDPC within this window for example because the full scope of the breach was still being assessed the NDPA permits a phased notification approach, provided the additional information is submitted without undue delay. The notification to the NDPC must include:

- The nature of the personal data breach, including the categories and approximate number of data subjects affected.
- The categories and approximate number of personal data records involved.
- The name and contact details of the Data Protection Officer or other designated contact.
- The likely consequences of the breach as best assessed at the time of notification.
- The measures taken or proposed to address the breach, including measures to mitigate its possible adverse effects.
-

Notification to Affected Data Subjects

Section 40(3) of the NDPA goes further: where the breach is likely to result in a high risk to the rights and freedoms of the data subjects, the CAC was also obligated to notify those individuals directly, and without undue delay. This communication must be written in clear, plain language and must explain:

- What happened; a plain description of the nature of the breach.
- What information was affected; the types of personal data involved.
- The likely impact on the individual.
- Steps the individual can take to protect themselves (such as monitoring financial accounts or placing fraud alerts).
- What the CAC is doing to address the breach.
- Contact details for a point of enquiry or the Data Protection Officer.

The obligation to notify affected data subjects is separate from, and in addition to, the obligation to notify the NDPC. Failing to notify data subjects when there is a high risk of harm is itself a breach of the NDPA, attracting additional penalties. Beyond the legal requirements, notification of affected individuals is also an ethical obligation those whose data has been exposed have a right to know so they can take protective action.

Penalties for Non-Compliance

Under the NDPA 2023, non-compliance attracts significant financial penalties. For Data Controllers of major importance, a category that a national institution like the CAC would almost certainly fall into — administrative fines can reach up to ₦10 million or 2% of annual gross revenue, whichever is higher. The NDPC has already demonstrated a willingness to levy substantial sanctions: its ₦766.2 million fine against Multichoice Nigeria and its \$220 million case against Meta Platforms confirm that enforcement is real and escalating. Failure to report the breach, or delayed reporting, would compound the CAC's legal liability significantly.

Question A3 — Remediation Strategy

Rebuilding institutional trust after a breach of this magnitude requires the CAC to go far beyond issuing public apologies. The following three-point high-level remediation strategy is designed to address the root governance failures, satisfy the requirements of ISO 27001:2022, and restore confidence in the institution as a trusted custodian of national corporate data.

1: Establish a Board-Sponsored Information Security Governance Framework

The CAC must embed information security governance at the highest institutional level. This means the Board or its equivalent must formally adopt an Information Security Policy, appoint a qualified Data Protection Officer (DPO) as required under the NDPA, and ensure that information security is a standing agenda item at every Board meeting not just when incidents occur.

Practically, this involves commissioning an independent ISO 27001:2022 gap assessment to establish a baseline against which progress can be measured. The output of that assessment should feed into a structured Information Security Management System (ISMS) implementation roadmap, with clear milestones, named accountable owners, and defined budgets. The CAC should target ISO 27001 certification within 18 to 24 months as a tangible demonstration of its renewed commitment to security governance. Leadership must also invest in regular security awareness training for all staff, because the human element remains the most exploited attack surface in any organization.

2: Implement a Technical Remediation and Hardening Programme

On the technical side, the CAC must address the specific vulnerabilities that likely contributed to or enabled the breach. This includes conducting an immediate forensic investigation to fully understand the attack vector, the extent of the data exfiltrated, and the dwell time of the threat actor in the environment.

Following the forensic review, the CAC should deploy multi-factor authentication (MFA) across all administrative and privileged access pathways, conduct a comprehensive review and pruning of all user accounts and service accounts (applying least-privilege principles), and implement a SIEM solution with 24/7 alert monitoring. All systems holding personal data should be brought up to current patch levels and placed under a formal vulnerability management programme that includes quarterly penetration testing. Encryption at rest and in transit must be enforced for all data classified as sensitive or personal.

3: Develop a Transparent Public Trust Restoration Programme

Technical controls alone will not restore public and business confidence in the CAC. The institution must actively demonstrate accountability and transparency. This means publishing a public breach notification report that honestly describes what happened, what data was affected, what the CAC is doing to address the harm, and what structural changes are being made.

Going forward, the CAC should establish an annual transparency report modelled on best practices from comparable national bodies internationally, covering the state of its data protection compliance, audit findings, and resolved incidents. Engaging proactively with the NDPC rather than reactively and inviting independent annual audits of its ISMS will signal institutional seriousness. Over time, achieving and maintaining ISO 27001 certification provides the most internationally credible signal that the CAC has transformed its security posture from reactive to proactive.

SECTION B: Payment Systems & Third-Party Risk Management

Question B1 — Third-Party Risk & Cascading Breaches

The Remita and Sterling Bank incidents illustrate one of the most dangerous and underappreciated dimensions of modern cybersecurity risk: the reality that an organization's security posture is ultimately only as strong as the weakest link in its entire ecosystem of third-party relationships.

Understanding Third-Party Risk

Third-Party Risk (TPR) or more formally, Third-Party Vendor Risk Management (TPRM) refers to the potential for harm arising from an organization's relationships with external entities: vendors, service providers, payment processors, cloud infrastructure suppliers, and partners who have been granted access to the organization's systems, data, or networks.

In the specific context of the Remita and Sterling Bank scenario, the risk materialized in a particularly damaging way. Remita, as a payment processing intermediary, occupies a privileged and deeply embedded position in the Nigerian government's financial infrastructure. It processes payments on behalf of numerous government agencies and financial institutions, which means that its systems hold aggregated data and keys belonging to multiple upstream organizations. A breach at Remita is therefore not just a Remita breach it becomes a breach of every institution that entrusted Remita with access to its financial flows. This is the cascading breach model: one compromised node in an interconnected system creates a failure that propagates outward through every connected relationship.

The alleged exposure of Hardware Security Module (HSM) keys is particularly alarming. HSMs are the physical devices that generate, protect, and manage cryptographic keys used to authorise high-value financial transactions. If those keys were genuinely compromised, the integrity of transaction authentication across connected systems must be treated as suspect, requiring emergency key rotation and a full forensic audit of transaction logs for any potentially fraudulent activity.

Compliance Controls a Bank Must Enforce on Payment Gateway Partners

Sterling Bank, as a regulated financial institution, bore a duty of care to its customers that extended to its contractual and oversight relationship with Remita. The following specific compliance controls should have been in force:

- **Contractual Data Processing Agreements (DPAs):** Every agreement with a payment processor must include a formal DPA under the NDPA 2023, clearly defining data handling obligations, security standards to be maintained, breach notification timelines, and liability allocation.
- **Annual Security Assessments and Penetration Testing:** The bank should have required Remita to undergo independent annual penetration testing and cloud security assessments,

with results shared with Sterling Bank's risk team. Certifications such as ISO 27001 and PCI-DSS (Payment Card Industry Data Security Standard) compliance should have been contractual prerequisites.

- **Vendor Risk Tiering and Ongoing Monitoring:** Remita, given its criticality, should have been classified as a 'Tier 1' or 'Critical' third party, attracting the highest level of oversight. This would include quarterly security reviews, continuous monitoring of publicly available threat intelligence relating to the vendor, and annual on-site assessments.
- **Access Minimization and Segregation of Duties:** The data and system access granted to Remita should have been scoped strictly to what was required for its operational role. Credentials allowing access to KYC document stores or cryptographic key material should never have been held by a third party without strong authentication controls and audit logging.
- **Incident Notification Requirements:** The DPA and service agreement must require Remita to notify Sterling Bank of any security incident within a defined short window ideally within two hours of confirmed awareness so the bank can activate its own incident response and regulatory reporting procedures without being delayed by a vendor's internal processes.
- **Right to Audit Clause:** Sterling Bank's contracts should have included an explicit right to audit Remita's security controls at any time, not merely when an incident occurs. Many cascading breach scenarios are entirely preventable if banks exercise this right proactively rather than discovering failures only after a catastrophic event.

Question B2 — KYC Data Protection & Legal Liability

The alleged exposure of over 800GB of KYC documents comprising government-issued identification documents, passports, bank statements, and related financial records represents one of the most serious categories of personal data breach possible under the NDPA 2023. KYC data is, by its nature, highly sensitive: it is the foundational material of personal identity, and its exposure creates immediate, tangible risks of identity theft, financial fraud, and long-term harm to affected individuals.

Legal Liability Under the NDPA 2023

Both Sterling Bank and Remita face concurrent legal liability under the NDPA 2023, and neither can fully escape responsibility by pointing to the other. Sterling Bank, as a Data Controller of its customers' KYC information, remains legally responsible for the protection of that data even when processing has been delegated to a third-party processor like Remita. The NDPA does not permit a Data Controller to simply outsource its compliance obligations it can only outsource the processing activity itself, and must ensure through contractual and audit mechanisms that the processor maintains equivalent safeguards.

Remita, to the extent it held and processed personal data on behalf of Sterling Bank and other clients, was acting as a Data Processor and bears its own independent obligations under the Act.

The fact that a data processor has suffered a breach does not extinguish the controller's liability; it is layered on top of it.

Financial and Administrative Penalties

Under the NDPA 2023, administrative fines for Data Controllers and Processors of major importance which both Sterling Bank (a regulated financial institution) and Remita (a systemically significant payment platform) would qualify as can reach up to ₦10 million or 2% of annual gross revenue, whichever is higher. Given the scale of the alleged breach, the involvement of multiple data subject categories, and the reputational sensitivity of the KYC data involved, regulators would be justified in applying penalties at or near the maximum threshold. Civil liability claims from affected individuals add further financial exposure, as Section 48 of the NDPA preserves data subjects' right to seek compensation for harm suffered as a direct result of a breach.

Reputational and Systemic Impact on Public Finance Infrastructure

The reputational consequences extend well beyond the institutions directly involved. Remita processes payments for dozens of federal and state government agencies. Sterling Bank serves a broad retail and commercial customer base. The public knowledge that HSM keys, KYC documents, and financial records were allegedly accessible to a threat actor will fundamentally undermine trust in the security of government payment systems at precisely the moment Nigeria is deepening its commitment to digital finance and the broader cashless policy agenda. Businesses required to transact with government will question the integrity of those transactions. Citizens whose identity documents are now potentially in criminal hands face the real prospect of fraudulent credit applications, SIM swap attacks, and benefit fraud carried out in their names. The Nigerian financial system's credibility in the eyes of international correspondent banks and investors also takes a significant hit a reputational cost that is genuinely difficult to quantify.

Question B3 — Audit Evidence for Cloud Security

As an auditor tasked with verifying whether Remita's cloud storage environment was properly configured and compliant with data protection obligations prior to the breach, the following five specific artefacts (items of evidence) would be requested from Remita's IT and Cloud Security teams. Each artefact is targeted at a specific dimension of cloud security governance.

1: AWS CloudTrail Logs and S3 Access Logs

CloudTrail provides a comprehensive, API-level audit trail of all actions performed on AWS resources, including S3 buckets. S3 access logs capture every HTTP request made to the bucket including GetObject, PutObject, DeleteObject, and ListBucket operations along with the requesting IP address, the IAM identity used, and the timestamp. Reviewing these logs prior to and during the period of the alleged breach would establish who accessed the data, from where, using what credentials, and whether access patterns were consistent with normal operations or indicated

anomalous exfiltration activity. The absence of these logs, or their having been disabled, would itself be a significant compliance finding.

2: S3 Bucket Policy Configurations and Block Public Access Settings

As an auditor I would request the current and historical bucket policy configurations for all S3 buckets holding KYC or sensitive data. Specifically, the review would examine whether Block Public Access settings were enabled at both the account and individual bucket level, whether bucket Access Control Lists (ACLs) contained wildcard principals (such as '*' or 'AuthenticatedUsers') that would permit any authenticated AWS user to read bucket contents, and whether any bucket policy contained conditions that were insufficiently restrictive. An exposed S3 bucket is one of the most common and most preventable cloud misconfigurations and a bucket storing 800GB of KYC data that was publicly accessible or accessible without MFA represents a fundamental compliance failure.

3: IAM Policies, Roles, and Access Key Review

As an auditor I would request a full IAM (Identity and Access Management) policy review, covering all users, roles, and service accounts with any form of read or write access to the relevant S3 buckets. This review would assess whether the principle of least privilege was being applied (i.e., no entity had broader access than its operational function required), whether inactive or dormant accounts had been deprovisioned, whether long-lived static access keys were in use (a significant vulnerability if stolen), and whether MFA was enforced on all human user accounts. Access key age reports from AWS IAM Credential Reports would also be requested to identify credentials that had not been rotated in accordance with policy.

4: AWS Config Rules and Compliance Assessment Reports

AWS Config continuously monitors and records the configuration state of AWS resources and evaluates them against defined compliance rules. As the auditor I would request the AWS Config rule set in place prior to the breach, the results of automated compliance evaluations, and any remediation actions that were triggered or manually applied. Evidence that Config rules were deployed but findings were not actioned or that Config was not enabled at all would demonstrate a governance gap between having cloud security tooling and actually using it. Conformance pack reports aligned to frameworks such as PCI-DSS, NIST 800-53, or CIS AWS Foundations Benchmarks would be particularly relevant.

5: Encryption Configuration Records and Key Management Policies

As the auditor I would review the encryption configuration for all relevant S3 buckets specifically whether server-side encryption was enabled using AWS KMS (Key Management Service) managed keys, whether encryption was also enforced in transit via TLS/HTTPS, and whether the KMS key policies followed appropriate access controls. Given the additional concern about HSM key exposure, the auditor would also request documentation of Remita's key management lifecycle, how cryptographic keys were generated, stored, rotated, and revoked as well as any Hardware Security Module configuration records. Evidence that key material was stored in the same

environment as the data it was meant to protect, or that key access logs showed anomalous access prior to the breach, would be critical forensic findings.

SECTION C: Executive Risk & Incident Response Strategy

Question C1 — Board-Level Risk Briefing

MEMORANDUM

TO: Board of Directors

FROM: Chief Information Security Officer (CISO)

DATE: Sunday 24th May 2026

RE: Urgent Risk Briefing — National Cybersecurity Breaches & Our Institutional Exposure

Executive Summary

Over the past several weeks, Nigeria has experienced a series of serious cybersecurity incidents involving the Corporate Affairs Commission (CAC), Remita, and Sterling Bank. As your CISO, my role this morning is to translate what happened in those institutions into plain business language, assess the degree to which our institution faces the same risks, and present a proposed course of action that is both prudent and immediately actionable.

What Happened; In Business Language

Three distinct but related failures have been reported. At the CAC, a threat actor known as ByteToBreach gained access to a national database holding millions of corporate and personal records and reportedly remained inside the system undetected for an extended period. This is the digital equivalent of a burglar breaking into a bank vault, spending weeks examining every document, and only being discovered when the documents appear on a criminal marketplace.

At Remita and Sterling Bank, an attack reportedly resulted in the theft of 3 terabytes of data, including over 800 gigabytes of KYC identity documents passports, national identity cards, bank statements and cryptographic keys used to authorize financial transactions. In simple terms: customer identities that took years to collect and verify are now potentially in criminal hands, and the keys that were supposed to guarantee the integrity of financial transactions may have been compromised.

The common threads are: systems that were not kept current with security patches, cloud storage that was not properly restricted, detection systems that either did not exist or were not actively monitored, and a governance culture that did not treat cybersecurity as a Board-level business risk.

Our Risk Exposure

I want to be honest with the Board: we are not immune to these risks. Any institution of our size and systemic importance that uses cloud infrastructure, processes KYC data, and relies on third-party payment infrastructure is exposed to the same categories of threat. The question is not

whether these risks exist for us they do; but whether we have the controls in place to detect and respond to an attack before it becomes a catastrophe.

Based on my current assessment, I am requesting Board approval for an immediate, targeted investment in three areas. These are not speculative requests; they are minimum requirements to bring our security posture into line with what the current threat environment demands.

Proposed Immediate Budget Increase

- **Enhanced Detection and Monitoring Capability approximately ₦250 million:** This covers the procurement or upgrade of a 24/7 Security Operations Centre capability, including SIEM tooling and Managed Detection and Response services. If we cannot see what is happening on our network in real time, no other investment matters.
- **Cloud Security Hardening and Configuration Audit approximately ₦100 million:** An immediate independent audit of all our cloud environments, including S3 configurations, IAM access controls, and encryption practices. The Remita and Sterling Bank incidents began with cloud misconfiguration; we must verify today that we are not carrying the same vulnerabilities.
- **Third-Party Risk Management Programme approximately ₦80 million:** A formal TPRM framework that imposes security standards on our critical vendors, including mandatory annual security assessments, breach notification obligations in contracts, and continuous monitoring of our most critical partners.

The total requested is approximately ₦430 million. For context, the average cost of a major data breach at a financial institution of our scale including regulatory fines, legal costs, customer remediation, and reputational damage runs into billions of naira. This is not an expenditure; it is an insurance policy for the institution's very survival.

Question C2 — Comprehensive Incident Response Plan (IRP) Activation

The following outlines the first 48 hours of our Incident Response Plan, from the moment unauthorized intrusion is detected. The plan is structured around three phases; Detect and Contain, Investigate and Notify, and Stabilize and Communicate and details the specific responsibilities of the Legal, IT Security, and Public Relations departments throughout.

Phase 1: Hours 0–4 Detect, Triage, and Initial Containment

The moment a suspicious indicator is identified whether by the SIEM, an analyst, or an automated alert the following sequence must be initiated immediately.

- **IT Security (Lead Role):** The Lead Security Analyst confirms the alert is not a false positive. Upon confirmation of a genuine intrusion indicator, the Security Incident Commander (typically the CISO or their deputy) is notified immediately, regardless of the time of day. Affected systems are isolated from the network to prevent lateral movement, the critical principle here is containment before remediation. The team does NOT wipe or rebuild affected systems at this stage, as doing so destroys forensic evidence that will be

legally required later. Forensic preservation of disk images, memory dumps, and relevant log files begins immediately.

- **Legal (Initial Role):** The General Counsel or Head of Legal is notified within the first two hours. Legal's initial task is to confirm the legal classification of the incident under the NDPA 2023 specifically, does this appear to be a breach involving personal data that creates a risk to data subjects? If yes, the 72-hour regulatory notification clock has now started. Legal also advises on evidence preservation requirements and ensures that all incident response communications are routed through legally privileged channels where possible.
- **Public Relations (Initial Role):** PR is notified but instructed to hold, no public statement is made at this stage. A brief holding statement is prepared for use only if a media enquiry arrives before the institution is ready to make a full public disclosure. This holding statement must be factually accurate, must not deny the incident, and must not contain any characterization of the scope or severity of the breach (since the institution does not yet know those facts).

Phase 2: Hours 4–24 Investigation, Escalation, and Regulatory Notification

- **IT Security (Lead Role):** Digital forensics proceeds in parallel with continued containment. The team works to establish the attack vector how did the threat actor gain entry? The likely scope of the breach, what data was accessed or exfiltrated, and for how long? The persistence mechanisms in place are there, additional backdoors or compromised accounts still active? External incident response specialists are engaged if the internal team does not have the capacity or specialist forensic tooling for the specific attack type. Password resets are enforced across privileged accounts, and MFA is verified as active on all administrative interfaces.
- **Legal (Lead Role for Notification):** By no later than the 24-hour mark, Legal must have drafted the regulatory notification for submission to the NDPC. Even if the investigation is incomplete, the NDPA requires notification within 72 hours of awareness waiting for a perfect picture before notifying is not legally defensible. The notification must accurately describe what is known, acknowledge what is still under investigation, and commit to phased updates. Legal must also identify any contractual notification obligations to institutional partners, correspondent banks, or insurance underwriters and ensure those notifications are dispatched within their own required timelines.
- **PR (Supporting Role):** PR works with Legal and the CISO to develop the internal communication the message that will be sent to staff explaining that an incident is under investigation and instructing employees on what they may and may not say to external parties. No external communication is made without Legal sign-off.

Phase 3: Hours 24–48 (Eradication, Notification, and Controlled Communication)

- **IT Security (Lead Role):** The eradication phase begins all identified malware, backdoors, and compromised credentials are purged. Rebuilt or hardened replacement systems are brought online in a controlled, staged manner. Monitoring is intensified across the entire environment to detect any residual attacker presence. A preliminary incident timeline is produced documenting the attack from initial entry point to containment, which will form the foundation of the post-incident review.
- **Legal (Lead Role for Data Subject Notification):** Where the breach is assessed as posing a high risk to data subjects which in a scenario involving exfiltrated KYC data, is almost certainly the case, Legal coordinates the notification of affected customers in plain language, in line with Section 40(3) of the NDPA. The notification must be honest about what happened, clear about the potential impacts, and practical about the protective steps individuals can take. Legal also manages the relationship with the NDPC during the 48-hour period, responding promptly to any information requests from the regulator.
- **PR (Lead Role for External Communication):** By the 48-hour mark, a prepared and legally approved external statement must be ready. The PR strategy during this period is one of controlled transparency: the institution acknowledges the incident, describes the immediate steps it has taken, expresses genuine concern for affected customers, and commits to a full post-incident review with public disclosure of findings. This is the most effective approach from a reputational standpoint institution that attempt to minimize, deny, or delay disclosure almost universally suffer more severe and lasting reputational damage than those that are proactive and honest. The CISO should be prepared to speak to media with approved key messages, projecting competence and calm authority rather than panic.

Cross-Cutting Principles Across All 48 Hours

- All decisions made during the incident response are documented in real time, with timestamps and the names of decision-makers, creating an audit trail for the NDPC and any subsequent legal proceedings.
- Communications about the incident must never travel over potentially compromised channels. If email or internal messaging systems are affected, out-of-band communication (separate mobile devices, encrypted messaging apps, or direct telephone) must be used.
- The CISO provides a brief status update to the Board of Directors no less than every six hours during the first 48-hour period, ensuring executive oversight is maintained throughout the crisis.
- At the conclusion of the 48-hour period, a post-incident review is scheduled for no later than two weeks following containment, with the objective of identifying root causes, gaps in the IRP, and the control improvements required to prevent recurrence.